Systems Administration ASIST

Topic 4

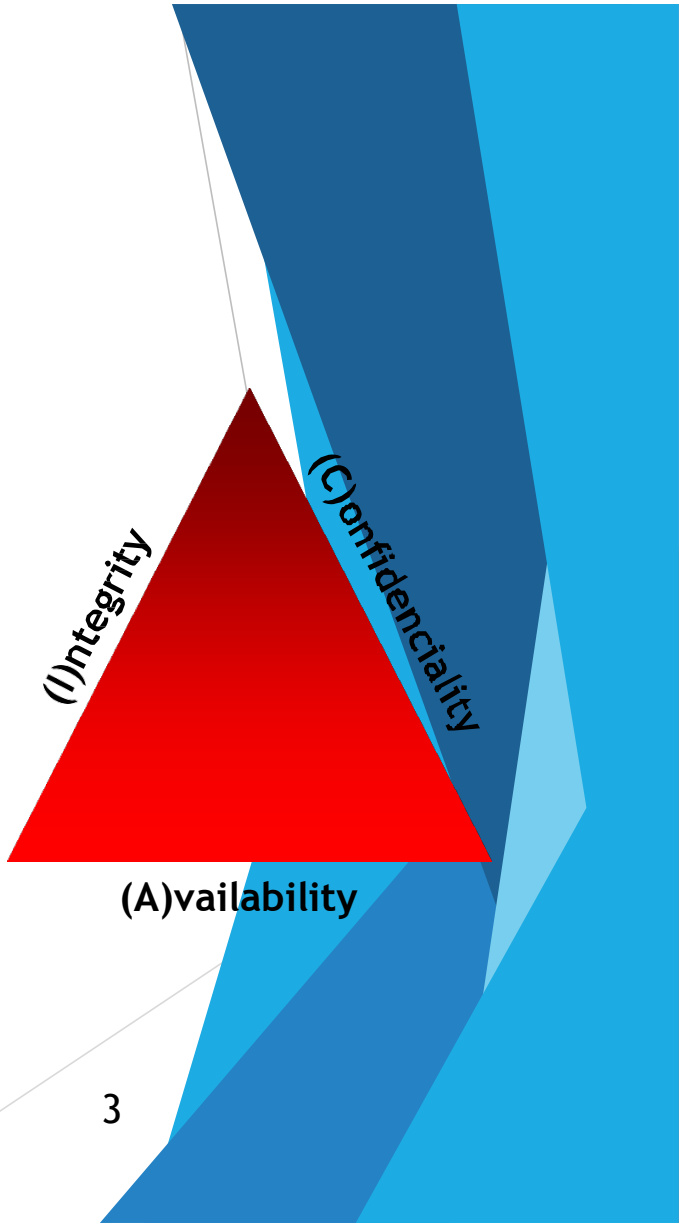
Cryptography

Cryptography

- The most valuable asset we have is data
- However high the cost is, a system and/or infrastructure can be replaced, but this does not necessarily apply to data
- The cost of losing data, or losing confidence in it, is not quantifiable and often impossible, which has numerous side effects
  - Legal, tax, operational, reputable, …
- And sometimes they are secret or private, so access by third parties leads to a loss of credibility and information leaks
- In other words, data is essential to the operation of each one, organization or person, and it matters that it is
  - **Credible**
  - **Available**
  - **Confidential**

Cryptography

- Note that these principles do not apply in the same way to all areas of the infrastructure (network, equipment, data)
- Within the announced principles, *availability* should be interpreted as *being available at the appropriate time (and/or time frame*)
- Security is understood as the concepts necessary for information to be available, certain and readable only to those authorized
- This concept can be (and is) extended to the infrastructure itself with the necessary changes or adaptations applicable
- The CIA triad (or CID in Portuguese) mirrors the foundation of security



Cryptography

- Confidentiality
  - Ensures that there is an appropriate level of secrecy at each processing node and that information leaks are prevented
  - It must exist throughout the system and not just in some parts
  - It can be obtained through
    - Encryption of saved and transmitted data
    - Secure communications
  - Annullable via
    - Communications monitoring
    - Social engineering
    - Theft of authentication credentials
- Without confidentiality, data can be read by those who do not have the appropriate authorization

Cryptography

- Integrity
  - Ensures system accuracy and reliability and prevents unauthorized data changes
  - Ensures that attacks and errors do not compromise information and the system
  - It can be obtained through:
    - Good capacity management of system agents
    - Intrusion detection mechanisms
    - Appropriate access controls
- Without guarantee of integrity, a system can operate on incorrect data without knowing it

Cryptography

- Availability
  - Ensures the necessary capacity to perform in a predictable manner and with acceptable performance
- Relevant actions that can be taken to ensure it are
  - Avoid single points of failure
  - Take measures to safeguard information
  - Include redundancy mechanisms
  - Ensure availability to those who need it
- May be affected by denial of service attacks



Cryptography

- The mechanisms to guarantee the first two principles (confidentiality and integrity) are based on the use of cryptography
- The third principle (availability) is based on different mechanisms
  - After all, what we want to guarantee with this principle is that an authorized user gets access to the data in the system in less than or equal to the defined SLA
- A complete cryptography course is not intended here, but only its basic principles

Cryptography

- Cryptography – kryptós (hidden) + gráphein (writing)
- Science and art of hiding text (information) so that it becomes indecipherable by third parties - objective when it started to be applied
- Used for thousands of years (Etruscans, Romans, etc.)
- Having a text (**P**) and applying the cipher with a key (**K**) a cipher text (**C**)is obtained
  - **$C = P \oplus K^{+}$** or **C = E(P,K)** or **C = Ke(P)**
  - **$P = C \oplus K^{-}$** or **P = D(C,K)** or **P = Kd(C)**
- Currently used either to make the text indecipherable to unauthorized entities or to authenticate it

Cryptography

- An ideal cryptographic system must be difficult to break, easy to use, robust (that is, two different texts must not result in the same cipher if the key used is the same) and easy to replace (if broken)
- Note the *difficult to break*
- The most accurate definition is to assume *difficult* as *impractical*

Cryptography

- Encryption alone is quite useless
  - It must be part of a wider system
- Compare encryption with a lock
  - By itself, it is useless
  - But if it closes an access to something except to whoever has the key, it becomes important
  - If we assume that the *thing* it gives access to extends to people, the problem assumes other behavioral dimensions
    - These people need to remember to close the lock when they leave and
    - They need to remember not to leave the key in sight or available

Cryptography

- And just like locks, there is *good* encryption and *bad* encryption
- In addition, encryption has to distinguish between *good* and *bad* access
  - Which is much more difficult than just keeping everyone on one side
- One thing to keep in mind is that it's unreasonable to apply "good" encryption while leaving weaknesses in the infrastructure
  - Imagine a bank safe with a fantastic door and lock but with a window inside the safe, with or without bars
- So let's assume a basic principle

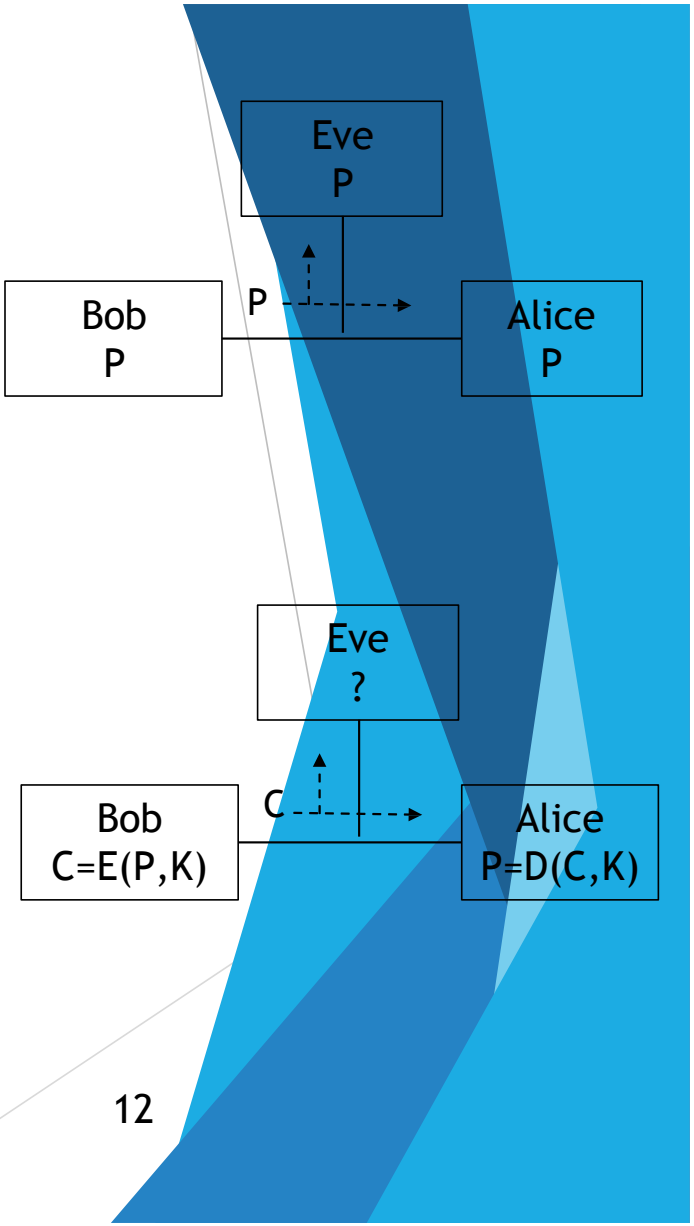
  The security of a system is as strong as its weakest point
- And yet another

  Cryptography is not the solution to security problems

  (but it is part of the solution)

Cryptography

- The primary purpose of cryptography was to encrypt/encrypt messages
- Bob and Alice want to exchange messages (**P**) between them but without Eve, who is listening, understands them
- What they can do is combine a secret between them (shared secret) that will be the key (**K**) and encrypt each message sent by applying an algorithm with that key, thus obtaining the ciphertext **C**
- The message recipient decrypts the message by applying the same **K** key but the reverse function
- Each stakeholder in the message needs to know the algorithm to apply and the key
- This example applies to data in communication but can and should also be applied to data stored in the system



Cryptography

- Of course, there are costs and constraints in the process
  - Which encryption/decryption algorithm to choose?
  - How robust is the key (secret)?
- Kerckhoffs defined in 1883 several principles applicable to cryptography that still apply - although adapted to today
- One of the principles is ***The security of an encryption system should depend only on the secret of the key and not on the secret of the algorithm***
- There are several reasons for this
  - Algorithms are difficult to develop and change
  - secret algorithms are difficult to distribute (though with some exceptions)
- Currently, the secrecy of the message is not enough
  - It is necessary to guarantee integrity and authenticity
  - And also, the non-repudiation (just think of the banks and the tax authority)

Cryptography

- In addition to the previous considerations, another one emerges
  - What to do if the algorithm is broken?
- Several authors have written on the topic
  - ***The enemy knows the system*** (Claude Shannon)
  - ***There are two ways to design a system. One is to make it so simple there are obviously no deficiencies. The other is to make it so complex there are no obvious deficiencies.*** (C. A. R. Hoare, quoted in Kaufman et al., Network security, p. 441)
  - ***Cryptography is rarely ever the solution to a security problem.*** (D. Gollmann, Computer Security, p. 203)

Cryptography

- Cryptographic systems can be typified by
  - **Algorithm**
    - Secret algorithm (used in the military)
    - Known algorithm
  - **Secret/Key**
    - Symmetric (shared secret)
    - Asymmetric (different encryption and decryption keys)
  - **Method**
    - Block
    - Continuous (*stream*)
  - **Application**
    - Reversible/bidirectional (Integrity, Confidentiality, Authenticity)
    - Irreversible/unidirectional (Integrity, Authenticity)

Cryptography

- Some constraints have already been described in the use of a secret algorithm
- It should be noted that the development of a secret algorithm, although possible, has drawbacks
  - How safe it is?
  - How it is distributed?
  - What guarantees do we have of robustness, that is, that two different texts do not produce the same number?
  - Who does its cryptanalysis?
- If we adopt a known algorithm we have the guarantee that the cryptanalysis of the algorithm and, if applicable, of its implementations have already been made

Cryptography

- Thinking about the secret, the most simple and usual way is the shared secret
  - It is used, as seen in previous topics, in passwords
- One possible method is **substitution**, which consists of replacing each character in the text with a different one
  - This is the method used in the Caesar Cipher
  - This figure consisted of replacing each character with another 3 (three) positions in the alphabet to the right (it wasn't exactly just that, but let's assume that way)
- If the cipher text is **C = ehpylqgrvdqryddxodghdvlvw**, what will be the message **P**?
  - $K^+ = 3 \leftrightarrow K^- = -3$
  - Encrypt: **a → d; e → h; z → c; …**
  - Decrypt: **e ← b; h ← e; c ← z; …**

Cryptography

- As an alternative to substitution, **transposition** (or permutation) can be made, which is based on changing the order of the text characters
  - Text: **Hoje temos aula de ASIST**
  - Adapted text: **H J t m s u a e S S**
    o e e o a l d A I T
  - Cipher: **HJtmsuaeSSoeeoaldAIT**

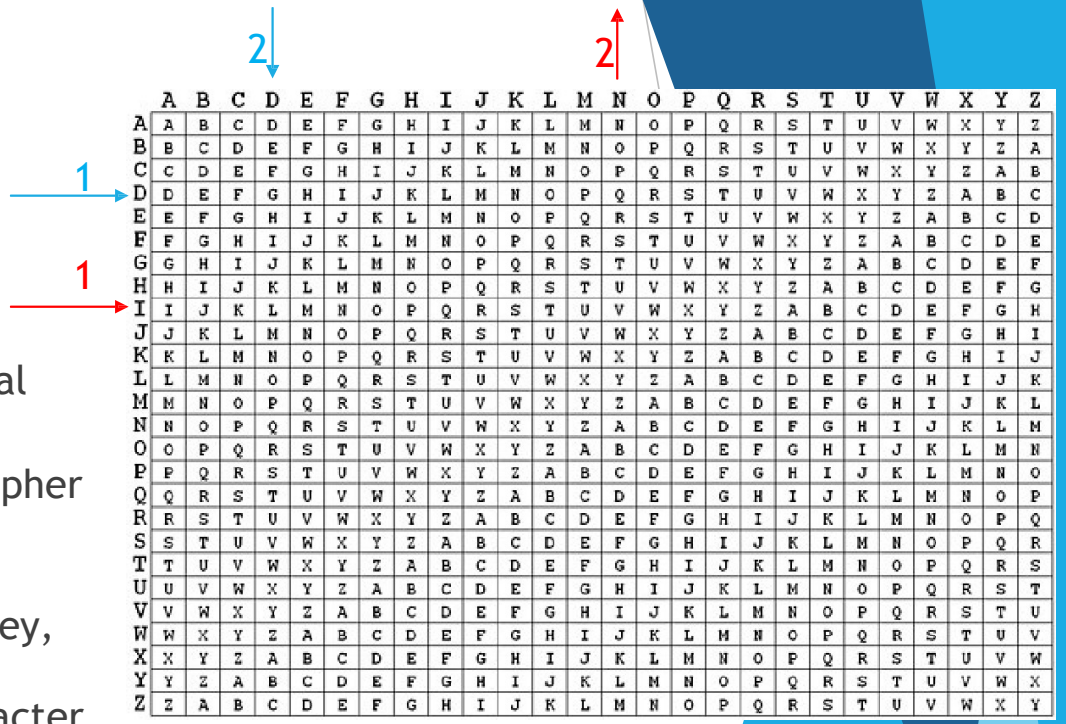
  - Key: **4132** (let's add a **"k"** to the text so that its size is a multiple of the key size)
  - Cipher : **eHjootmelasuaSdAekITS**

Cryptography

- The shared secret is desirable for several reasons, of which it stands out as the method with the best performance in encryption and decryption operations
- However, it has several drawbacks
  - For a pre-shared secret to be effective, it must be exclusive to a pair of entities
    - That is, for N entities there must be $C_{(n,2)}$ (combinations of N two by two)
  - The high number of secrets leads to human problems
    - For 100 (one hundred) entities, it is necessary $C_{(100,2)} = \frac{100!}{2!*(100-2)!} = 4950$ secrets!
  - Also in a practical context, how do we share the secret with an entity? Sending by SMS?

Cryptography

- The Caesar Cipher has the drawback that equal characters produce equal ciphers
- The Vigenère Cipher is based on the Caesar Cipher principle but changes the characters in a non-constant way
- Instead, it uses an array of characters and a key, replacing each letter of the text P with the character at the intersection of the text character with the corresponding character of the key
- Example:
  - Text: **Qual o dia da semana? → qualodiadasemana?**
  - Key: **asist → asistasistasista**
  - Cipher: **qmidhdaivtswusga?**



Cipher: character at the intersection of the line of the corresponding letter of the key with the column of the letter of the text
Decipher: column letter that contains the cipher character at the intersection of the corresponding letter line of the key

Cryptography

- Alternatively, there is the asymmetric cipher
- It is based on the use of different algorithms and keys for encryption and decryption
- In the asymmetric cipher **Ke <> Kd**
- It is also known as a **public key cipher** because **Ke** can be made public since only the **Kd** (secret) allows decryption
  - In fact, a plaintext can also be encrypted with the **Kd** key and decrypted with the **Ke** key
- This method is heavy in terms of processing, therefore unsuitable for large volumes of data
- At the same time, it is easy to use as it does not require a key exchange (secret)
- Often used to securely negotiate a shared secret

Cryptography

- My public key:

-----BEGIN PGP PUBLIC KEY BLOCK-----

mQGNBGJQU0EBDACrwZQ98o5Lxk18HefD6bC7ri1f7QgmgoyiaDHa5SmsnCxL72LI
WQuPzEaXD4oQe+YqNFQ9HSspE/PaZw9gouYEXnOdZygtEpbbTXqUR+SmecQr637I
kGBWRXAX5+1NR7Od0S8jNoT96XzDyO80ZMlaIeaXVRLnhJRkIUdA5RnFCt85/jWm
+7jAMb0woPVzMeHTSGPhrEfYO+qLAjPq6yyqjDCkj1RjltoEKGaaFKesJt6p6deM
sCkSMOpOiWmBI71gVuSzgPnt63JXaL1ZubnkHyeglL4fj/j9ewbvW+Gwc6Ic9MDL
jkwp/3NH1NwellcHi1stpg/FMwrWQqN6w+SNCbPixG9hF7oR7rvSiw9UDEqYY9SJ
OdjR6U1DIkZKs2IwyqEEHXXCrEPeaAYujZTEDufYfrXiBh0ocHqEdP2d4KK4psQ8
x/JbjmzxFX0MVUCiPSGk4wc9+90yXkXOVEBC9udKMkareFyCyBqjPH6SqqExIrc/
3DzRNoTv6vTsnssAEQEAAbQjSm9yZ2UgUGludG8gTGVpdGUgPGpwbEBpc2VwLmlw
cC5wdD6JAc4EEwEIADgCGwMFCwkIBwIGFQoJCAsCBBYCAwECHgECF4AWIQQ73in2
iCYMAh6y9CNwcBn0rY848wUCYlBTrgAKCRBwcBn0rY848z7aC/sHQXIpIQRM8Vfr
ZQupxZvlPD7i0KJdmnMkJckB6pJmF4IXn7dvOoaseRDFRWtWVWj6YtY/QOkncpM2
s/Ij7PWRda20a+qPqLYhxog5zMokkX2duac1aQqIDBiXuiC2yl9cELTxH9IRDhhj
uxJVZE7sb6Bennll2U/rV2wuWSiUlx5cw2x0t/2EKtVlnVjn79uyzj+8n5/C68kx
cRtzHrvxCv/8RqfcwmO3x01cOm8HkTvrD1O/93nxfys9Gi6DqjwgZHDZwXfx4jFB
Mw7Q4NH1rACkShH5F+7Z5h68bpWu2c3DdrFazqUOO37EE4RA7Cb60y13feSIJ6JS
NvNN4vlL1so5pBMrBu1b3NqkPVKm7Yn62h6CfdlCQrO+RNtNDTgZuj2q897Yjmx3
OdZNQasX8XjO9b5EDALIChdvC6h10bKozimHFzjSO85fRN19/Mi12KsB7FwInmiH
0dpsl4EUD5gOLQRIXpuphUVgQDCh68Xq+J/EVZMlXtrz5enEKz25AY0EYlBTQQEM
AMpdZr8OoDFvNvUIQ0rnpaH1pFud6nLkPZveDshmmHcrQlBj9MNm9/yhKjHyK1+S
xcAVbfkRw+aKk0KGW4MjRa9+ky/DQC7U1ZGBiTv+LihtZWxb6qDS2dWXa7bnBD8y
i5DwB6ZQocOhtCoUu+UkHv57O8Etp2/dQ24P8nxCyMbfF4OvCEH6jO3tlE4Rds7o
NRmNyIEdP8/mCSJC69Joi63ZdvWO6ySQBW6UEpzS5ohCyzvujhO2FAZaHOX7bz8M
MauyoR89EWGUW0dgwKWMqInY89XbyYs+LI1qHv2XRfjlPT0ksEOillLxMfcCC7jv
nz3ppxKKltRFp0/vhm7g++0u9XJfJutzHN7cHcnRApDHqOknMspLuHM8eoSF9w9i
NLdvKu1F9x/7jLZ5CD5JMISHTVVFakrVdtzSKrFCe2x1bgOYirgTO5TENSqcFPWc
KEqxV6RAu1dQ+sD72uNLQs2YnzLXFPz5EHqs0gp774gQN7OxPPrPgRl6BTYphGRt
CQARAQABiQG8BBgBCAAmFiEEO94p9ogmDAIesvQjcHAZ9K2POPMFAmJQU0ECGwwF
CQPDeu8ACgkQcHAZ9K2POPOThQv/XqUCc2MqpVldbWC2pAl0HgL1/2QfMcSnsNtt
HMn0a83+bUKJ+N1C3vZd+rjegTAFYwC/noK+L6viOqIqwbZ50kk15hSEKffDxjG/
N6rdIMMn9wO3vJGisvd11fD0oPCLfZwbSGmKsIruGV+fgJTWL6HlGBN3FBFS4qT+
4jC7Y+aNdT1aUU2CKcvKJ9K4AFtBaoro4hQ1Ej7zJpQ4oUzawXBcoDaUlcQMIRG7
MntAV3YHB9s+XhVUQuHZLSSi6C2B2wnkms6WH2+IiO/Y1ztm8p92iP8P7YyBJFbJ
r7BUc5OUcfEqu4t3IDCDvTS6ch7PNgumGcgSY+sTCnnO2ZXt3oV5bIF6ga7pgRZn
Bc3gG7Rnn+qZ1stIdXrBd2s+9wAYtBRIXbbx044wZf9A7DSz//yJ62BXZ1lPiRaC
56U1OSRA1VvINaHIV1UFsDLK8fEHwZeuy+AfD+A6PS62ymy9sfI7VKzZCeCNTmWI
C8qYlENregzy03iQJnx22D8emn/z
=sSOT
-----END PGP PUBLIC KEY BLOCK-----

Cryptography

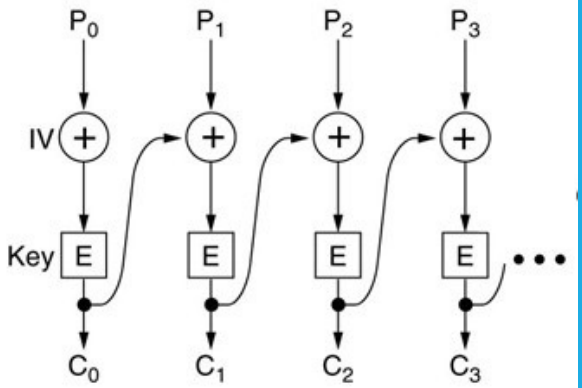
- We already mentioned that the cipher method can be block or continuous (stream)
- In the case of block, the original text is divided into equal-sized parts, namely, $\mathbf{P = P_1P_2P_3...P_N}$
- Each part is encrypted with the same key **K**
- A padding is added to the text or the key is truncated in the final block so that the dimensions of the parts (text and repeated keys) are equal
- In block cipher $\mathbf{C = K(P_1)K(P_2)K(P_3)...K(P_N)}$

Cryptography

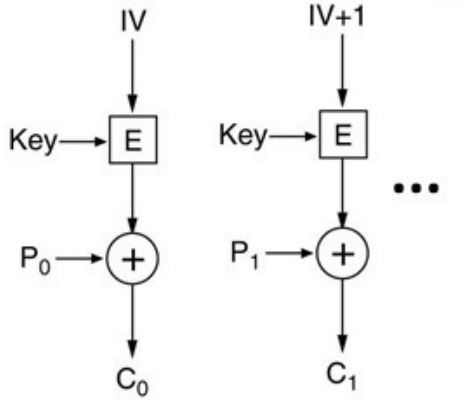
- Example of application of the block cipher
  - Text P: **Vamos experimentar uma cifra**
  - Key: **fcp** (Vigenère method)
  - TO text divided into blocks: **vam ose xpe rim ent aru mac ifr a**
  - Hypothesis 1: add a padding (let's assume **te**)
    - Text P + *padding* : **vam ose xpe rim ent aru mac ifr ate**
    - Chave: **fcp fcp fcp fcp fcp fcp fcp fcp fcp**
    - Cipher: **acb tut crt wkb jpi ftj rcr nhg fvt**
  - Hypothesis 2: truncate the key in the final block
    - Text P: **vam ose xpe rim ent aru mac ifr a**
    - Key: **fcp fcp fcp fcp fcp fcp fcp fcp f**
    - Cipher: **acb tut crt wkb jpi ftj rcr nhg f**
  - As expected, all cipher blocks are the same, varying only the last

Cryptography

- This method has the drawback that equal text implies equal cipher
  - What makes possible, for example, attacks that look for the frequency of each character in the applied language
- This method is called *Electronic Code Book* (**ECB**)
- Alternative methods can be used, like
  - *Cipher Block Chaining* (**CBC**)
    - The encryption for each block (excluding the first) is applied to the next block (usually through an **XOR** operation) and the result is encrypted
  - *Counter* (**CTR**)
    - An initialization vector is applied to the key and the result of this application is that it is used as a key for the block
    - The initial vector can even be zero, but the following ones are incremented by a predetermined value
  - There are other methods but the goal is similar



Encriptação CBC



Encriptação CTR

Cryptography

- In the continuous case, the original text is divided into parts of equal size, ie, $P = P_1P_2P_3...P_N$ on what $\forall x \in (2, N)\ sizeof(P_x) = sizeof(P_{x-1})$
- Each part is encrypted with a different key $K = K_1K_2K_3...K_N$
- The number of keys **K** can be less than the number of parts of the text **P**, in which case a key can be repeated
  - Assuming in this way as a **periodic key**
- In the continuous cipher $C = K_1(P_1)K_2(P_2)K_3(P_3)...K_N(P_N)$
- And, if periodic, it can be for example $C = K_1(P_1)K_2(P_2)K_1(P_3)...K_1(P_N)$



Cryptography

- The problem here is always the key, its size, the greater or lesser difficulty of a third party in obtaining the text **P** having access to **C**
- ***Keyspace*** is defined as the number of possible keys given its size and characters allowed in each position
  - Bank card code
    - 4-character numeric key
    - Each position can assume 10 different values (zero to nine)
    - Keyspace= 10^4 = 10000
- Assuming a message in Portuguese in which the key uses all uppercase characters (A to Z including K, W and Y) and has the same dimension (N) as the text to be encrypted, the space is $\mathbf{N^{26}}$, which makes it impossible to decipher except those who hold the key
- This is the principle of the ***One Time Pad*** (**OTP**)

Cryptography

- As for the application, cryptography can be
  - **Reversible/bidirectional** also called ***two-way***
  - **Irreversible/unidirectional** also called ***one-way***

- It is considered a reversible/bidirectional application if it is possible to obtain the text **P** having access to the cipher **C**

- It is considered an irreversible/unidirectional application if it is impossible to obtain the text **P** by accessing the cipher **C**
  - Or rather, impractical

Cryptography

- If the cipher is bidirectional, it must be
  - **Simple**
    - The encoding and decoding of **P** is easy given the key **K**
  - **Resistant**
    - Given a text **P** and the corresponding **C** it is impracticable to calculate **K**
  - **Uniqueness (collision resistance)**
    - Given a text **P** and the corresponding **C** it is impractical to calculate a key **K'** such that **Ek(P) = Ek'(P)**

Cryptography

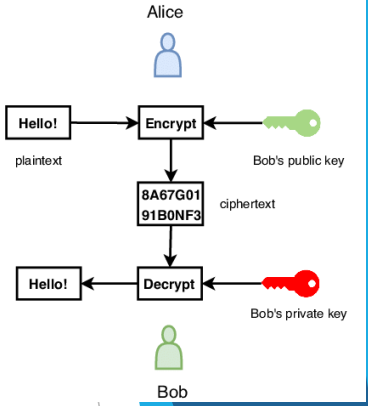
- If the cipher is unidirectional it must be
  - **Simple**
    - **P** coding is easy given the key **K** and results in a fixed length result **H**
  - **Irreversible**
    - It is impracticable to invert **H** ($P \neq H^{-1}(C)$)
  - **Uniqueness (collision resistance)**
    - Given any **P1** text it is impractical to find another **P2** such that **H(P1) = H(P2)**
    - If the collision resistance is weak, then there may be a **P1** and a **P2** such that **H(P1) = H(P2)**

Cryptography

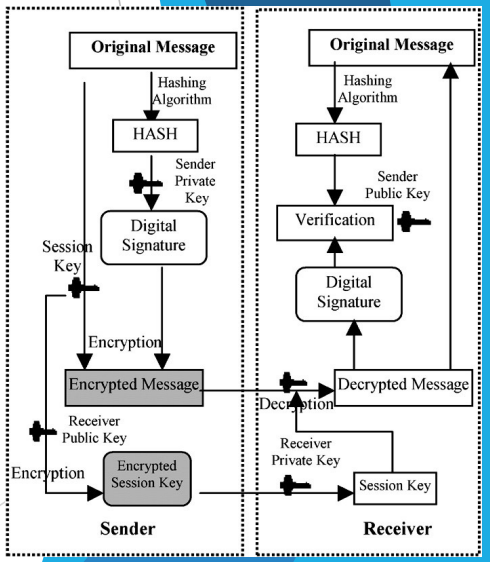
- But why the unidirectional cipher?
- As mentioned, initially the purpose of cryptography was to hide or obscure a text through encryption
- But if this operation makes it impossible for an unauthorized third party to understand the cipher, it does not prevent that third party from altering some characters in the cipher - which may even result when deciphering into a valid text (although necessarily different from the intended text))
- The purpose of the unidirectional cipher is to authenticate the text by generating a ***hash*** or ***Message Authentication Code*** (**MAC**) that is attached to the cipher **C**
  - The MAC has a fixed size that depends on the cryptographic algorithm used

Cryptography

- The use of an asymmetric figure allowed **non-repudiation**, a property already mentioned (slide 13)
- If the generated *hash* is signed with the issuer's private key
  - The receiver can decrypt it with the sender's public key and verify the integrity of the message
  - The sender cannot repudiate the validity or authorship of the message
  - It is called **digital signature** the *hash* signed with the issuer's private key
- Non-repudiation can be achieved in other ways but with processing costs
  - Encryption with the recipient's public key, then with the issuer's private key
  - Decrypts with the sender's public key, then with the receiver's private key



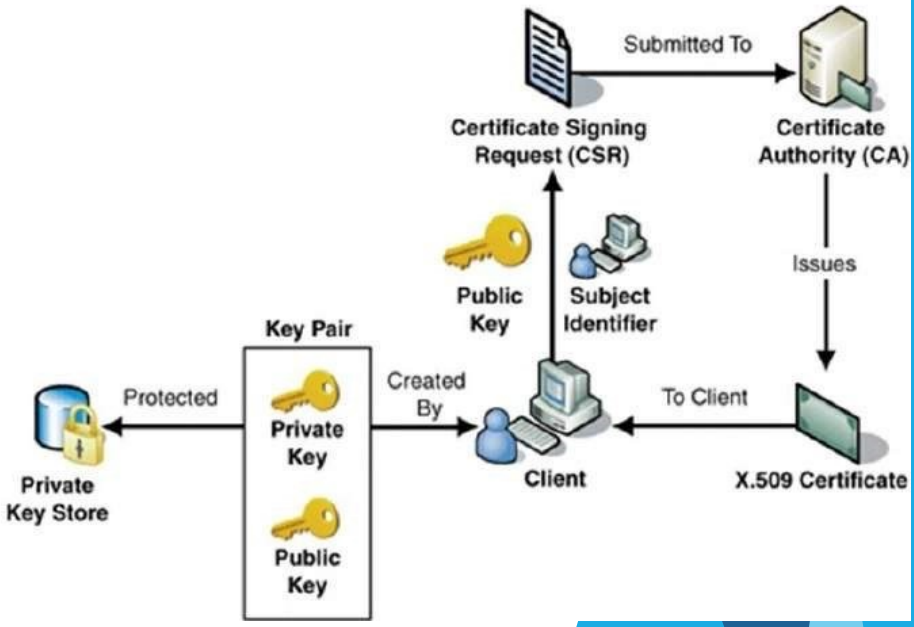
Source: ResearchGate



Source : ResearchGate

Cryptography

- As an example of the asymmetric key take a look in the *Public Key Infrastructure* (**PKI**)
- Enabled the use of encryption without the problem of key exchange
- **PKI** consists of a set of rules, procedures, policies, applications and facilities that are physically and logically secure
- The goal is to make it reliable to generate, manage, distribute, store, use and revoke digital certificates and digital keys
- This theme will be deepened in the theoretical-practical classes



Source: TutorialsPoint

Cryptography

- It has already been mentioned that the asymmetric cipher is not suitable for large volumes of data
- However, it has significant advantages in the distribution of keys, in the authenticity of the sender/receiver, etc.
- Why not use a mixture of both?
  - Using asymmetric cipher a shared secret is negotiated between the peers
    - That is, the possibility of using a symmetric cipher
  - Use the negotiated shared secret to encrypt and decrypt information

Cryptography

- The application of the security triad (Confidentiality, Integrity, Availability) is not limited to communication between parties
- Information stored on storage devices also needs to be subject to cryptographic operations to
  - Assist data confidentiality
  - Validate data integrity
- With regard to communications, these algorithms are used in applications and/or protocols that have replaced older versions and are currently considered unsafe
  - Some examples are **SSH**, **VPN**, **TLS**, **IPsec** and the **802.11i** standard
- Note that the application of a cryptographic algorithm in one layer does not prevent the application of another in a different layer, although it has a cost in processing

Cryptography

- Encryption application must be planned and implemented correctly
- There is usually a tendency to imagine and consider encryption only during data communication
- There is no doubt that in these circumstances it should be applied, but if and only if the information circulating is sensitive
  - There is no need to encrypt all the information because it represents a cost in terms of bandwidth occupation and infrastructure performance
- But keep in mind that stored data can and should be protected using encryption
  - Applying the same principle of proportionality as what should or should not be protected